TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

Billing-фишинг под Hetzner с VPS Hetzner Cloud и захваченным DNS

Phishing • DNS Hijacking • Google Redirector Abuse • Cloaking • Credential Theft • Cybercrime

Параметр	Значение
Дата анализа	**21 октября 2026**
Классификация	**Credential-фишинг: billing-приманка хостера**
Актор	**Неназванный финансово мотивированный оператор (мультибренд, активен минимум с июня 2026); не связан с параллельным случаем под YouTube (High)**
Цели	**Клиенты хостеров (Hetzner, DreamHost, Strato), ИИ-сервиса и банков**
Затронутые системы	**Аккаунты получателей в Hetzner; DNS-зоны захваченных доменов**
Ключевые техники	**Захват DNS легитимных доменов, собственный MTA в облаке провайдера, отмывка через редиректор Google, многоступенчатый cookie-гейт**
Уровень угрозы (оценка риска кампании)	**HIGH**
Источники	**Заголовки и тело письма; пассивный DNS, прозрачность сертификатов, RDAP, публичные архивы сканов**

1. Краткое резюме

20 октября 2026 года billing-фишинг под Hetzner Online дошёл до реального клиента Hetzner, который распознал фишинг и не взаимодействовал с письмом. Отдельное письмо, исследованное параллельно, с этой кампанией не связано (уверенность High).

Письмо отправлено с выделенного VPS внутри самого Hetzner Cloud (2[.]29[.]109[.]211). Домен отправителя singermali[.]com является легитимным доменом 2018 года (DreamHost), DNS которого захвачен: актор добавил запись для собственного MTA, SPF, разрешающий только этот VPS (-all), и DKIM-ключ с селектором в виде Unix-времени. Поэтому SPF, DKIM и DMARC проходят. Единственная ссылка идёт через редиректор уведомлений Google (notifications.googleapis[.]com/email/redirect), который прячет настоящую цель (значение zlib + base64url в параметре r=) за доменом Google. Цель, hz.azrylin[.]com, закрыта JavaScript-гейтом и размещена на сервере, где также живёт кластер свежих мультибрендовых двойников (Hetzner, DreamHost, Strato, OpenAI/ChatGPT, Piraeus Bank, Openbank). Второй захваченный домен DreamHost (jaggery[.]org) настроен по тому же DNS-шаблону, а сертификаты 21 октября показывают подготовку следующей волны.

Влияние: кража учётных данных аккаунтов хостинга/облака. Компрометации жертв не наблюдалось. Оценка риска кампании: High (контроль над аккаунтом у хостера).

Ключевые выводы:

- Фишинг отправляется из облака имитируемого провайдера и проходит SPF, DKIM и DMARC, потому что актор контролирует DNS захваченного легитимного домена.
- DNS-шаблон актора на захваченных доменах: MX 10 mta.<домен> на адрес Hetzner Cloud; v=spf1 ip4:<IP> -all; DMARC p=none с rua=postmaster@<домен>; DKIM-селектор <unixtime>.<метка>.
- Отмывка ссылки через редиректор Google: видимый и первый домены принадлежат Google. Посадка защищена многоступенчатым cookie-гейтом (jscheck, screen, серверная проверка), который отбракованных посетителей отправляет на настоящий бренд.
- Кампания — часть активной мультибрендовой операции (минимум с 23 июня 2026) с двойниками хостеров, ИИ-сервиса и банков на двух серверах (37[.]148[.]201[.]157, 208[.]116[.]19[.]38).

2. Хронология

Дата / время	Событие
2026-06-23	Сервер 208[.]116[.]19[.]38 в работе (имя узла PowerMTA)
2026-07-26	Первые сертификаты двойника DreamHost panel-dreamhost[.]com
2026-08-24 / 25	Зарегистрированы двойники OpenAI и Strato
2026-10-12	Зарегистрированы azrylin[.]com, azrylin[.]net, azryliz[.]com
2026-10-15	На 37[.]148[.]201[.]157 развёрнут Plesk
2026-10-20 ~03:30 UTC	Выпущен сертификат hz.azrylin[.]com
2026-10-20 06:32:18 UTC	Создан DKIM-ключ singermali[.]com (селектор = Unix-время)
2026-10-20 08:42 – 16:49 UTC	Жалобы на 2[.]29[.]109[.]211 в публичной базе абьюз-репортов (рассылка этой кампании)
2026-10-21 ~00:00 – 02:00	Сертификаты app-openbank[.]com, gty.singermali[.]com,

UTC	srv.jaggery[.]org: готовится следующая волна

3. Billing-фишинг под Hetzner

3.1 Письмо

Тема «Update your payment method to avoid suspension»; текст сообщает о неудачном платеже и приостановке услуг через 7 дней, если не обновить способ оплаты. Display name «Hetznar Online Gmbh» (опечатка) при адресе support@singermali[.]com; в подвале фальшивый лондонский адрес («24 Commerce Street, Suite 900»), тогда как настоящая компания находится в Германии; обращение «Dear Customer», номера клиента нет. Письмо состоит из одной HTML-части с inline-логотипом PNG.

Наблюдения по заголовкам (все подтверждены):

- Последний внешний хоп: mta.singermali[.]com [2[.]29[.]109[.]211] по TLS 1.2; SPF pass для единственного адреса; DKIM pass (d=singermali[.]com, селектор 1792477938.singermali, RSA-2048); DMARC pass при p=none.
- Селектор DKIM — Unix-время 2026-10-20 06:32:18 UTC: ключ создан примерно за два часа до первой зафиксированной отправки (08:42 UTC).
- Message-ID имеет точный формат Python email.utils.make_msgid() с именем Windows-хоста (WIN-6U7R9EBBET1), MIME-граница тоже от Python. Заявленный «X-Mailer: Mozilla Thunderbird» противоречит обоим признакам и подделан. Заголовок Date содержит смещение UTC-07:00 (слабый признак).
- Самописные заголовки «X-Spam-Status: No, score=0.0», «X-Spam-Checker-Version: SpamAssassin (version 3.4.0)», «X-Spam-Report: This message is not spam.» во входящем письме, а также Precedence: bulk и X-Auto-Response-Suppress: All.

3.2 Инфраструктура отправителя и захват DNS

2[.]29[.]109[.]211 принадлежит Hetzner Cloud (AS24940, диапазон выделен 2026-09-29, стандартный reverse DNS Hetzner). Следовательно, фишинг против клиентов Hetzner отправляется с сервера Hetzner. Домен отправителя singermali[.]com зарегистрирован с 2018 года и использует NS DreamHost с 2019 года; его сайт остаётся на общем хостинге DreamHost (67[.]205[.]27[.]194, не индикатор). Зона изменена 2026-10-20 по шаблону актора (раздел 1). Тот же шаблон, указывающий на другой адрес Hetzner Cloud (178[.]105[.]10[.]8), присутствует на jaggery[.]org (регистрация 2004). Это компрометация аккаунтов владельцев доменов, а не их соучастие (High). Возможный источник аккаунтов DreamHost — двойник panel-dreamhost[.]com, активный с 26 июля (Medium).

3.3 Отмывка ссылки и посадочная страница

Кнопка ведёт на notifications.googleapis[.]com/email/redirect с тремя параметрами: непрозрачный токен t=, подпись s= и r= — целевой URL, сжатый zlib и закодированный base64url. Декодирование r= показывает настоящую цель на hz.azrylin[.]com. Форматы t= и s= принадлежат Google и признаком актора не являются. Сервер посадки сначала отвечает 72-байтной страницей, которая ставит cookie jscheck=1 и перезагружается; с этим cookie он отдаёт вторую, 104-байтную страницу, которая ставит cookie screen=<ширина>x<высота> по размеру экрана посетителя и снова перезагружается. Это многоступенчатый гейт с отпечатком браузера: клиенты без выполнения JavaScript (сканеры, curl, краулеры) его не проходят, дальнейшие ступени не исключены; не-жертвам показывается декой-блог или редирект на настоящий hetzner.com. Кит за гейтом не наблюдался, поэтому поля формы и endpoint вывода данных неизвестны; вероятная цель — учётные данные аккаунта Hetzner и данные карты.

Если обе cookie выставлены, сервер выполняет серверную проверку. Тестовый запрос с обеими cookie с нерезидентного адреса получил HTTP 302 на настоящий hetzner.com с пустым телом: посетитель отбракован, вероятно, по репутации адреса либо потому, что путь, уникальный для письма, уже использовался (Medium). Итоговая схема гейта: jscheck=1, затем screen=<ширина>x<высота>, затем серверная проверка (адрес, client string, cookie), затем кит либо редирект на настоящий бренд. Кит за гейтом не наблюдался.

3.4 Кластер двойников

37[.]148[.]201[.]157 (GoDaddy NL, Plesk с 15.10) и 208[.]116[.]19[.]38 (WHG, имя узла PowerMTA) образуют один кластер: перенос panel-dreamhost[.]com и drliny[.]com с одного сервера на другой 13-16 октября и разнесение имён azrylin.* между обоими серверами связывают их (High). Все имена на 37[.]148[.]201[.]157 — фишинговые или декой-сайты, поэтому это не общий хостинг. Домены: consels-hetzner[.]com (Hetzner), panel-dreamhost[.]com (DreamHost), billing-openia[.]com, billng-chatgpt[.]com, chatgpt-opania[.]com, azryliz[.]com (OpenAI/ChatGPT), app-strato[.]com (Strato), ebanking-piraeusbank[.]com (Piraeus Bank), app-openbank[.]com (Openbank), а также azetd[.]com, ww-one[.]com, ony1[.]net с неясным назначением и декой drliny[.]com. Большинство зарегистрировано через Cloudflare Registrar с DNS Cloudflare; на origin-серверах используются отдельные сертификаты Let’s Encrypt на хост.

3.5 Оператор и выбор целей

Неназванный финансово мотивированный оператор, атакующий клиентов хостеров, ИИ-сервиса и банков; активен минимум с 23 июня 2026 и ежедневно готовит новые волны. Возможности: собственный MTA/PowerMTA, ротация VPS Hetzner Cloud, захват DNS чужих доменов, клоакинг. Атрибуции до именованной группы нет. Выбор целей, вероятнее всего, массовый (Medium): письмо обезличено, оператор ведёт параллельные приманки под других провайдеров; жалобы на отправляющий адрес поступали из нескольких стран в течение восьми часов. Утечка клиентской базы ничем не подтверждена (Low).

4. Связь с другими кампаниями

Письмо с приманкой об авторских правах YouTube, исследованное параллельно, с этой кампанией не связано (уверенность High): инфраструктура, кит и мейлер не имеют ничего общего. Связь с более ранней августовской приманкой Netflix, использовавшей тот же редиректор Google, не подтверждена (другой мейлер и инфраструктура; Medium, что операторы разные).

5. Индикаторы компрометации (IOC)

Все значения дефанжены. to_ids показывает, пригодно ли значение для списков блокировки. singermali[.]com и jaggery[.]org — скомпрометированные легитимные домены: блокировать нужно перечисленные ниже субдомены, а не сами домены. 67[.]205[.]27[.]194 (общий хостинг DreamHost), notifications.googleapis.com и youtube.studio индикаторами не являются.

Тип	Значение	Контекст / уверенность	to_ids
IP	2[.]29[.]109[.]211	MTA актора, VPS Hetzner Cloud (AS24940, диапазон HEL1). High	true (short-lived)

IP	178[.]105[.]10[.]8	Подготовленный MTA для mta.jaggery[.]org (AS24940). Medium	true
IP	37[.]148[.]201[.]157	Хост посадочных страниц (GoDaddy NL / Host Europe, AS21499, Plesk). High	true
IP	208[.]116[.]19[.]38	Хост посадок / PowerMTA (WHG, AS209341). High	true
Domain	azrylin[.]com	Домен актора, зарегистрирован 2026-10-12 (Cloudflare Registrar). High	true
Hostname	hz.azrylin[.]com	Посадка приманки Hetzner. High	true
Domain	azrylin[.]net	Домен актора. High	true
Hostname	account-one.azrylin[.]net	Хост актора на 37[.]148[.]201[.]157. High	true
Domain	azryliz[.]com	Домен актора (биллинг-приманка OpenAI/ChatGPT). High	true
Hostname	mta.singermali[.]com	Имя MTA актора на домене с захваченным DNS. High	true
Hostname	gty.singermali[.]com	Готовящаяся посадка (сертификат выпущен 2026-10-21). High	true
Hostname	mta.jaggery[.]org	Тот же DNS-шаблон, MTA на 178[.]105[.]10[.]8. High	true
Hostname	srv.jaggery[.]org	Готовящаяся посадка (сертификат выпущен 2026-10-21). High	true
Domain	singermali[.]com	СКОМПРОМЕТИРОВАННЫЙ ЛЕГИТИМНЫЙ ДОМЕН (регистрация 2018, DreamHost; DNS захвачен). Жертва, не блокировать как инфраструктуру актора. High	false
Domain	jaggery[.]org	СКОМПРОМЕТИРОВАННЫЙ ЛЕГИТИМНЫЙ ДОМЕН (регистрация 2004, DreamHost; тот же DNS-шаблон). Жертва. High	false
Domain	consels-hetzner[.]com	Двойник Hetzner. High	true
Domain	panel-dreamhost[.]com	Двойник DreamHost, сертификаты с 2026-07-26; возможный источник захваченных аккаунтов DreamHost	true

		(Medium). High	
Domain	billing-openia[.]com	Двойник OpenAI. High	true
Domain	billng-chatgpt[.]com	Двойник OpenAI. High	true
Domain	chatgpt-opania[.]com	Двойник OpenAI (включая субдомен billing[.]). High	true
Domain	app-strato[.]com	Двойник Strato. High	true
Domain	ebanking-piraeusbank[.]com	Двойник банка Piraeus. High	true
Domain	app-openbank[.]com	Двойник Openbank (сертификат 2026-10-21). High	true
Domain	azetd[.]com	Тот же кластер, назначение неясно. Medium	true
Domain	ww-one[.]com	Тот же кластер, назначение неясно. Medium	true
Domain	ony1[.]net	Тот же кластер, назначение неясно. Medium	true
Domain	drliny[.]com	Декой-сайт кластера (блог «рецептов»). Medium	false (decoy)
Domain	ayalti[.]com	Апекс узла PowerMTA (А также указывает на сторонний адрес). Medium	false
Hostname	pmta.ayalti[.]com	Узел PowerMTA на 208[.]116[.]19[.]38. Medium	true
Email	support@singermali[.]com	From / Return-Path этой кампании (адрес на домене с захваченным DNS). High	false
Email	unsubscribe@singermali[.]com	List-Unsubscribe этой кампании. High	false
Header	WIN-6U7R9EBBET1	Хост-часть Message-ID (Windows-хост отправителя). High	false
Header	s=1792477938.singermali	DKIM-селектор = Unix-время 2026-10-20 06:32:18 UTC. High	false
Header	^\d{10}\.[a-z]+$	Шаблон DKIM-селектора актора. High	false
String	Hetznar Online Gmbh	Display name (опечатка) приманки. High	false
String	24 Commerce Street, Suite 900	Фальшивый лондонский адрес в подвале. High	false

String	Update your payment method to avoid suspension	Тема приманки. High	false
String	document.cookie='jscheck=1; path=/'; location.reload();	Весь 72-байтный ответ гейта посадки. High	false
String	document.cookie='screen='+screen.width+'x'+screen.height+'; path=/'; location.reload();	Весь 104-байтный ответ второй ступени гейта (после jscheck=1). High	false
SHA256	5297362709b04b678399af1d68137fb857086149a275e1758760da79f1741132	Inline-логотип PNG приманки (вероятно, подлинный пресс-логотип Hetzner; слабый признак). Medium	false
SHA256	6d6054771a352d3d54c81d54d18af6c3ee06ce3ebf7d4d960d4180c41529e965	104-байтная страница второй ступени гейта (cookie screen=WxH). High	false
SHA256	1ffd13d1c1c64480376a47ed7c3c257d4e39df2ede1af1d6c52007b699c2a7c1	72-байтная страница-гейт ступени 1 hz.azrylin[.]com. High	false

6. Сопоставление с MITRE ATT&CK

Тактика	Техника	ID	Основание / статус
Reconnaissance	Search Open Technical Databases	T1596	Возможный отбор клиентов хостера по ASN. Возможно
Reconnaissance	Gather Victim Identity Information: Email Addresses	T1589.002	Ролевые адреса (вида info@, hello@). Возможно
Resource Development	Acquire Infrastructure: Domains	T1583.001	azrylin.*, кластер двойников. Подтверждено
Resource Development	Acquire Infrastructure: VPS	T1583.003	MTA на Hetzner Cloud; Plesk-хосты у GoDaddy NL и WHG. Подтверждено
Resource Development	Compromise Infrastructure: Domains	T1584.001	DNS singermali[.]com и jaggery[.]org под контролем актора. Подтверждено
Resource Development	Acquire Infrastructure: Web Services	T1583.006	Редиректор уведомлений Google. Подтверждено
Resource Development	Stage Capabilities: Link Target	T1608.005	hz.azrylin[.]com. Подтверждено
Initial Access	Phishing: Spearphishing Link	T1566.002	Ссылка в billing-письме. Подтверждено
Initial Access	Valid Accounts: Cloud	T1078.0	Цель: аккаунты Hetzner. Гипотеза

	Accounts	04	
Execution	User Execution: Malicious Link	T1204.001	Требуется клик. Подтверждено (замысел)
Defense Evasion	Impersonation	T1656	Биллинг Hetzner. Подтверждено
Defense Evasion	Masquerading: Match Legitimate Resource Name or Location	T1036.005	«Hetznar Online», consels-hetzner[.]com. Подтверждено

Отмывка через редиректор Google и клоакинг (cookie-гейт jscheck/screen, серверная проверка, декой-блоги, редирект на настоящий бренд) точно в ATT&CK не отображаются и описаны в тексте.

7. Детектирование

7.1 Почта

- Ссылки на notifications.googleapis.com/email/redirect в письмах, где From не Google: декодируйте r= (Python: zlib.decompress(base64.urlsafe_b64decode(r + "=" * (-len(r) % 4)))) и оценивайте декодированную цель, а не домен Google.
- DKIM-селектор, подходящий под ^\d{10}\.[a-z0-9-]+$ (селектор = Unix-время, ключ создан за часы до рассылки).
- Message-ID, подходящий под ^<\d{12}\.\d+\.\d{15,20}@WIN-[A-Z0-9]{11}>$, вместе с X-Mailer: Mozilla Thunderbird.
- Входящее внешнее письмо с самописными X-Spam-Status: No, score=0.0 и X-Spam-Report: This message is not spam.
- Display name содержит «hetzn», а домен From не hetzner.com (аналогично для других брендов: несовпадение display name и домена).
- DNS: домен, у которого MX/A указывает на хост mta.<домен>, SPF «v=spf1 ip4:<один IP> -all» и DMARC p=none с rua=postmaster@<тот же домен>, изменённые незадолго до рассылки.

7.2 Сеть и контент (строки для YARA / прокси / краулеров)

- Тело HTTP-ответа в точности равно: <script>document.cookie='jscheck=1; path=/'; location.reload();</script> (гейт, ступень 1).
- Тело HTTP-ответа, начинающееся с <script>document.cookie='screen='+screen.width+'x'+screen.height и далее location.reload() (гейт, ступень 2, 104 байта). Обе строки вместе (jscheck=1 и screen='+screen.width+'x'+screen.height) идентифицируют гейт.
- Хост, который после выставления cookie jscheck и screen отвечает 302 на домен настоящего бренда с пустым телом (результат серверной проверки гейта).
- Новые сертификаты и новые имена на 37[.]148[.]201[.]157 и 208[.]116[.]19[.]38 следует считать новыми волнами.

8. Рекомендации

Немедленные действия

- Блокировать или оповещать по индикаторам с to_ids=true; не блокировать singermali[.]com и jaggery[.]org целиком.
- Добавить правила раздела 8 на почтовый шлюз и веб-прокси; провести ретроспективный поиск по теме письма с брендом Hetzner и по ссылкам редиректора с недекодированным r=.
- Клиентам хостеров: настоящие счета Hetzner приходят с noreply.billing@hetzner.com; проверять биллинг нужно, открывая консоль напрямую, а не по ссылкам из писем. Подозрительные письма с полными заголовками следует пересылать в abuse- или support-канал провайдера так, как описано в его документации.

- Владельцам доменов у массовых регистраторов/DNS-провайдеров (DreamHost и др.): проверить DNS-зоны на неизвестные записи MX, SPF и DKIM, включить двухфакторную аутентификацию в панели управления.

Долгосрочные меры

- Публиковать DMARC p=quarantine/reject и отслеживать изменения DNS собственных доменов; оповещать о новых DKIM-селекторах и изменениях SPF.
- Почтовая защита не должна считать домен Google в ссылке сигналом доверия: перед оценкой нужно раскрывать цель редиректора.
- Со стороны провайдеров: отслеживать исходящий фишинг из собственных облачных диапазонов, особенно из недавно выделенных блоков; оперативно реагировать на жалобы о подделке бренда самого провайдера.
- Взять два серверных адреса из раздела 5 на мониторинг пассивного DNS и сертификатов.

9. Уверенность и ограничения

Вывод	Уверенность
Письмо — credential-фишинг	High
2[.]29[.]109[.]211 — VPS актора внутри Hetzner Cloud	High
singermali[.]com и jaggery[.]org — легитимные домены с захваченным DNS	High
Отправитель и посадка принадлежат одному оператору; кластер двойников на двух серверах	High
panel-dreamhost[.]com — источник захваченных аккаунтов DreamHost	Medium
Отбор целей по ASN хостинга	Medium
Не связано с параллельным письмом под YouTube	High
Кит (поля, вывод данных)	Не установлено (гейт)

Пробелы: кит за гейтом не наблюдался (гейт отбраковал тестовый запрос); источник аккаунтов DreamHost — гипотеза. Все страницы и индикаторы отражают состояние на 21 октября 2026, инфраструктура ротируется ежедневно.

10. Источники

- Hetzner Docs, «Phishing email collection» (docs.hetzner.com/general/security-and-identify/phishing-email-collection/).
- Mimecast, «Google Redirect Abuse»; TechRepublic, «Trusted Google Alerts Hijacked» (злоупотребление редиректорами Google в фишинге).
- Пассивный DNS, прозрачность сертификатов, RDAP/WHOIS, публичные архивы сканов URL и публичные базы абьюз-репортов (состояние на 21 октября 2026).

Дата отчёта: 2026-10-21

TLP:CLEAR — Этот документ может распространяться без ограничений.